Threat Intelligence & Digital Trust System — Architecture Blueprint

Project Name: TrustPulse Threat Intel & Trust Platform

Monorepo Layout: 3 Git Worktrees (main, backend-dev, frontend-dev)

Security Boundary: Strict Zero-Trust SSRF IP Pinning & Validation

Document Type: Technical Architecture Blueprint

Key Technologies: FastAPI (3.12), Next.js 16, Hardhat, Solidity 0.8.28

Integrity Layer: Keccak-256 On-Chain Proofs (No Raw URLs/PII)

1. Executive Summary & Problem Statement

Modern web security confronts two escalating threats:

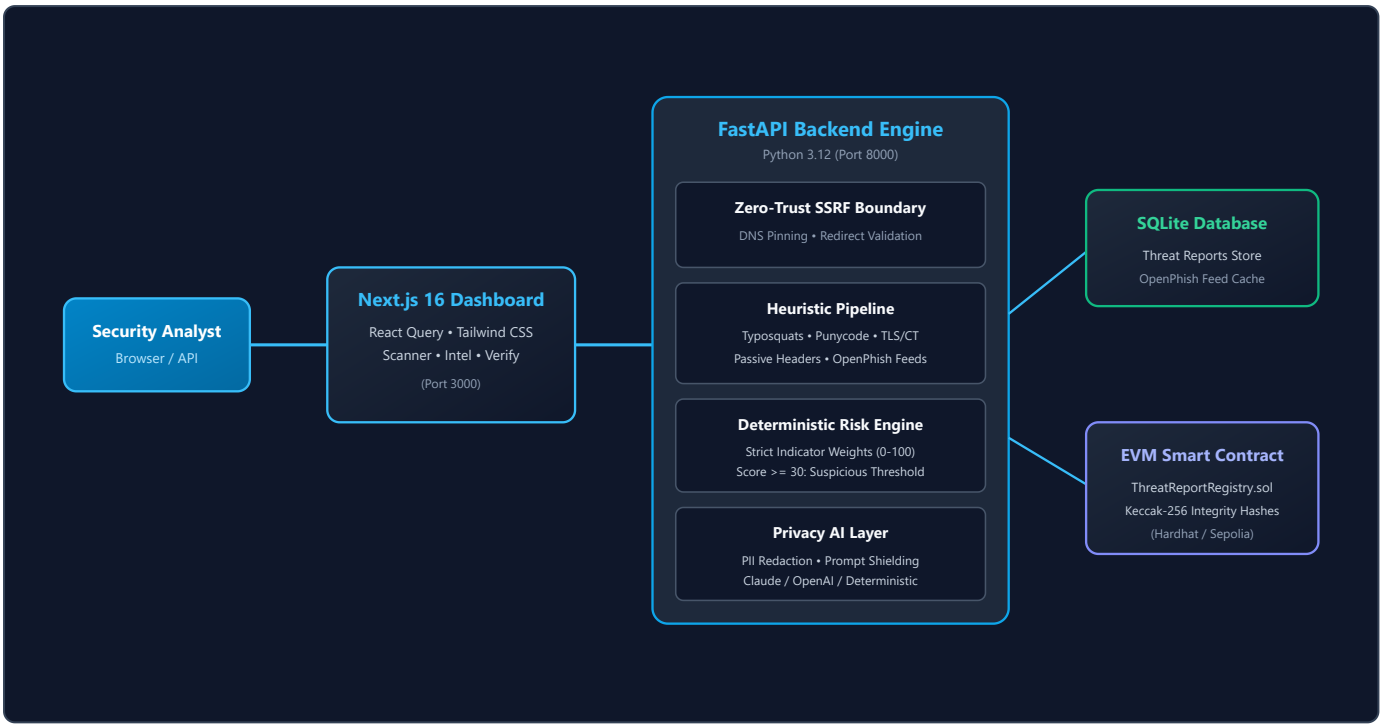
1. **Adaptive Social Engineering & Phishing**: Attackers evade perimeter blocklists using subtle brand typosquatting, Punycode homographs, short-lived DV certificates, and urgent psychological pretexts.
2. **The Centralized Scanner Trust Dilemma**: Centralized detection feeds act as unverified black boxes whose verdicts can be retroactively edited, backdated, or deleted.

Our Solution integrates multi-vector heuristic analysis with an immutable Ethereum/EVM on-chain registry (`ThreatReportRegistry.sol`) that cryptographically timestamps scan verdicts without placing user private data or raw URLs on-chain.

2. Core Architectural & Security Invariants

- **Never Call a Site "Safe"**: Absence of known indicators is not proof of safety. The system designates benign sites as: *"No significant indicators found in the available checks."*
- **A Valid TLS Cert is Never Proof of Safety**: Over 85% of phishing infrastructure uses valid Let's Encrypt certificates. The engine analyzes Certificate Transparency (CT) logs and CA reputations.
- **Deterministic Verdicts Only (AI Never Decides Risk)**: Risk classifications and scores are calculated exclusively by deterministic heuristics and authoritative feeds. The LLM only generates structured explanations.
- **Zero-Trust SSRF Protection (Scanner Must Not Become a Threat)**: Outbound fetcher strictly resolves and pins public IPs, rejects loopbacks, cloud metadata (169.254.169.254), hex/octal bypasses, and re-validates all redirect hops.
- **No PII or Raw URLs On-Chain**: Only a canonical Keccak-256 digest and a category string are submitted to smart contracts. Full user privacy is preserved.
- **Blockchain Proves Integrity & History, Not Truth**: On-chain anchoring proves a scan existed at a specific timestamp and has not been altered; it does not claim the external website itself is trustworthy.

3. High-Level System Architecture



4. Multi-Workspace Repository Layout

```
kernal-fresh/
├── kernal-v2/                # Main Integration Workspace (branch: main)
│   ├── docs/                 # API Contracts, Architecture, Bug Reports & Screenshots
│   │   ├── API_CONTRACT.md   # Strict JSON contract for frontend-backend interfaces
│   │   ├── BUG_REPORT.md     # Full QA audit & regression test suite
│   │   └── audit-screenshots/ # Automated high-res UI audit captures
│   ├── docker-compose.yml    # Multi-container service definitions
│   └── README.md             # Unified quickstart & developer documentation
│
├── wt-backend/               # Backend Worktree (branch: backend-dev)
│   └── backend/
│       ├── app/
│       │   ├── ai/           # Privacy masking, provider abstraction, prompt shielding
│       │   ├── analyzers/    # DNS, headers, intel, phishing, redirects, TLS
│       │   ├── api/          # FastAPI routers (health, scan, reports, intel)
│       │   ├── core/         # SSRF fetcher, defanging, risk engine, database
│       │   ├── models/       # Pydantic schemas and SQLAlchemy ORM models
│       │   └── web3/         # Web3 registry client and canonical report hasher
│       ├── contracts/        # Hardhat project: ThreatReportRegistry.sol & tests
│       ├── scripts/          # Seed fixtures, local chain runner, feed refresher
│       └── tests/            # 130+ unit and integration tests (pytest)
│
└── wt-frontend/              # Frontend Worktree (branch: frontend-dev)
    └── frontend/
        ├── app/              # Next.js 16 App Router (/, /report/[id], /intel, /verify)
        ├── components/       # Cyber SOC theme widgets, tabs, modal, risk badges
        ├── lib/              # Typed API client, error formatters, contract types
        └── public/           # Assets and branding
```

5. Component Technical Breakdown

A. Zero-Trust SSRF & Network Boundary

- **Mediated Transport**: Every HTTP connection occurs strictly through `safe_fetch()`.
- **Connection Pinning**: Resolves IPv4 (`A`) and IPv6 (`AAAA`) records, verifies `is_global`, and connects directly to `http://<IP>:<PORT>` while passing original hostname in `Host` and TLS SNI extensions to defeat DNS rebinding.
- **Redirect Sanitization**: Up to 5 redirects are inspected; every destination is re-validated through the SSRF pipeline before opening the socket.

B. Heuristic Detection Pipeline

- **Phishing & URL Structure**: Typosquatting (Levenshtein distance against top global domains), Punycode Cyrillic homographs, subdomain depth, and RDAP registration age (< 30 days flags risk).
- **TLS & CT Logs**: Analyzes X.509 validity, queries `crt.sh` for certificate issuance spikes, and cross-references against a distrusted Certificate Authority database.
- **Passive Headers**: Assesses HSTS, CSP, X-Frame-Options, X-Content-Type-Options, and Referrer-Policy.
- **Threat Intel Feeds**: OpenPhish community feed cache and Google Safe Browsing API v4 lookups.
- **Message Analysis**: Regex extraction of URLs/phones/emails, detecting urgency pressure and recruitment fees.

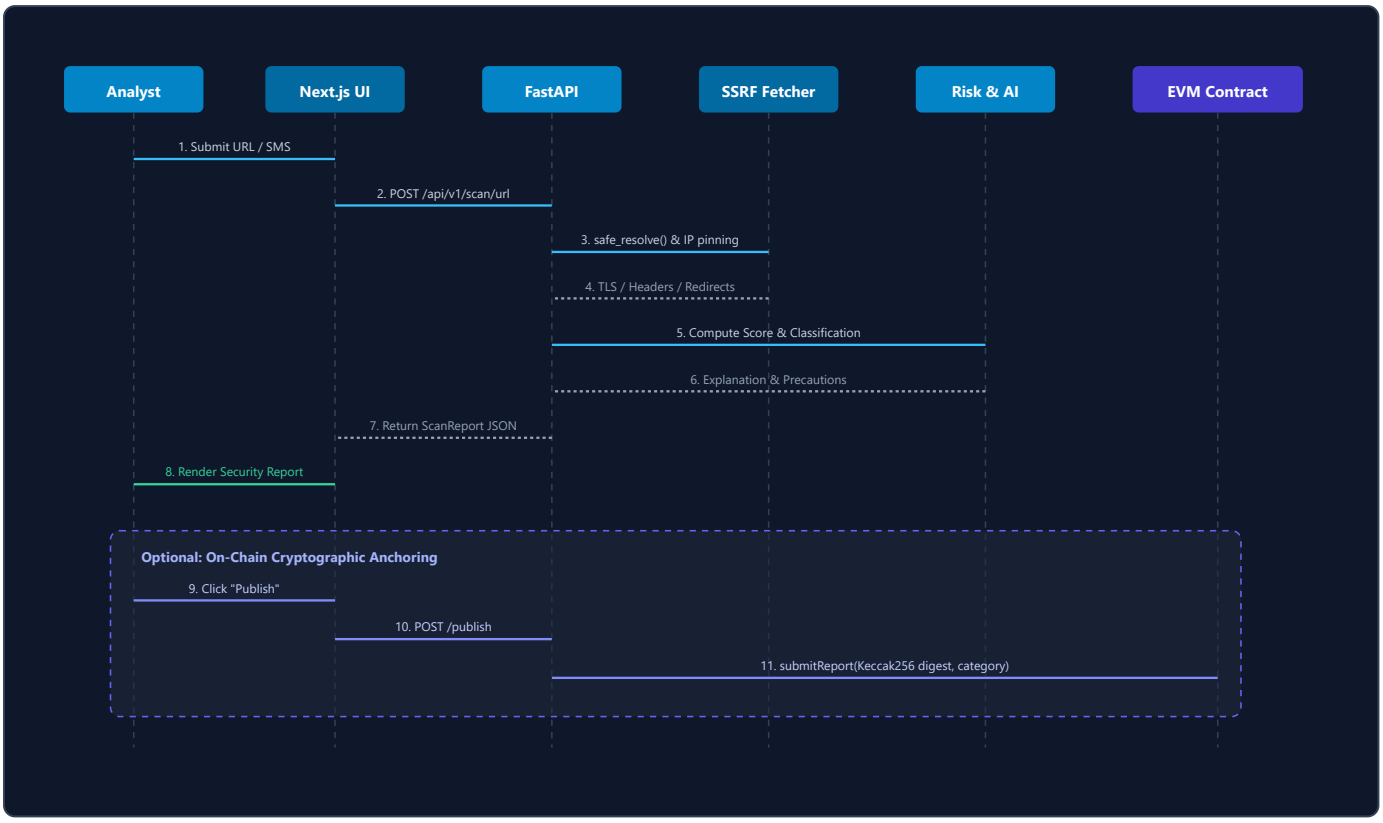
C. Deterministic Risk Engine

- **Formula**: `Score = min(100, sum(Weights(Indicators)))`
- **Weights**: `info (+2)`, `low (+8)`, `medium (+20)`, `high (+35)`, `critical (+55)`.
- **Classifications**:
  - `confirmed_malicious`: Authoritative threat intel hit.
  - `high_risk`: Score ≥ 70 with 2+ high indicators.
  - `suspicious`: Score 30-69 or typosquatting/homograph detected.
  - `low_risk`: Score < 30 with checks completed.
  - `inconclusive`: Key checks (DNS/fetch) failed.

D. Web3 Digital Trust Registry

- **Smart Contract**: `ThreatReportRegistry.sol` on EVM.
- **Canonical Serialization**: Normalizes JSON stripping user PII, free text, and raw URLs.
- **Cryptographic Proof**: Canonical JSON is hashed using `Keccak-256`.
- **Tamper Detection**: Verifying recalculates the current database record digest against the on-chain event log. Any database edit immediately flips `match` to `false`.

6. End-to-End Scan & Publish Sequence



7. API Contract Quick Reference

Endpoint	Method	Input Payload / Parameters	Return Object
`/api/v1/health`	GET	None	`{"status": "ok", "service": "...", "version": "1.0.0"}`
`/api/v1/scan/url`	POST	`{"url": "https://example.com"}`	Full `ScanReport` with indicators, TLS, headers, risk
`/api/v1/scan/message`	POST	`{"message": "KYC expired..."}`	`ScanReport` with message_analysis & urgency signals
`/api/v1/reports`	GET	`?risk=suspicious&limit=20&offset=0`	`{"items": ScanReport[], "total": number}`
`/api/v1/reports/{id}`	GET	Report UUID	`ScanReport`
`/api/v1/reports/{id}/publish`	POST	Report UUID	`ScanReport` with populated `onchain` receipt & tx_hash
`/api/v1/reports/{id}/verify`	GET	Report UUID	`VerifyResult` (`match: bool` , history, mandatory note)
`/api/v1/intel/correlations`	GET	None	`{"clusters": Cluster[]}` (shared redirect networks, IPs)

8. Ideas for Brainstorming & Future Iterations

- **Computer Vision Brand Matching**: Render candidate landing pages in headless browser and compute SSIM/perceptual hashes against legitimate corporate login portals.

- **Containerized DOM Sandbox**: Execute JavaScript within a secure ephemeral micro-VM to catch runtime credential stealers and dynamic phishing payloads.
- **Decentralized Oracle Integration (Chainlink)**: Allow smart contracts across DeFi to query URL trust ratings before approving interaction with unknown protocols.
- **Zero-Knowledge Scan Proofs (zk-SNARKs)**: Provide verifiable cryptographic proof that a security audit occurred without disclosing sensitive indicator details.
- **Autonomous Agent Investigation**: Agentic recursive pivoting to map out adversary server networks across ASN clusters.